

Modelo de Encuesta Integral OWASP 2025 – España

Versión 1.0 – Borrador para pilotos sectoriales

Público objetivo: CISOs, responsables de TI, responsables de riesgo, compliance y equipos de desarrollo/DevSecOps de organizaciones sujetas (o cercanas) a ENS y/o NIS2 en España.

0. Instrucciones para la persona encuestada

- La encuesta está diseñada para ser respondida por una o varias personas que conozcan bien la realidad de la organización (idealmente, CISO o equivalente, Responsable de TI, Responsable de Desarrollo, Responsable de Riesgos).
- Use la opción que mejor refleje la situación real, no la deseada ni la que aparece en las presentaciones al Comité.
- Cuando una pregunta no aplique, marque “No aplica” y, si es posible, explique brevemente por qué.
- El tono es deliberadamente ameno e irónico en algunas opciones; la intención es ayudar a la reflexión, no señalar con el dedo.

Se recomienda completar la encuesta en bloques, pudiendo involucrar a diferentes áreas en cada bloque (por ejemplo, desarrollo para ASVS, riesgos para métricas, etc.).

Bloque 1 – Perfil de la organización

P1.1. Tipo de organización principal

Seleccione la opción que mejor describa su entidad.

- Administración pública (AGE, CCAA, EELL, organismos públicos, universidades públicas).
- Empresa privada – sector esencial NIS2 (energía, transporte, salud, banca, infraestructuras digitales, etc.).
- Empresa privada – sector importante NIS2.
- Proveedor TIC (servicios gestionados, cloud, desarrollo de software, etc.).
- Otra (especificar brevemente).

P1.2. Tamaño aproximado de la organización (empleados)

- Menos de 50.
- 50–249.
- 250–999.
- 1.000–4.999.
- 5.000 o más.

P1.3. Ámbito principal de operación

- Principalmente España.
- España y otros países de la UE.
- Global (UE y fuera de la UE).

P1.4. Situación respecto al ENS

- No aplica (no estamos sujetos al ENS ni por contrato ni por colaboración con el sector público).
- ENS en fase de adaptación (plan de adecuación en curso, sin certificación aún).
- ENS certificado – categoría BÁSICA.
- ENS certificado – categoría MEDIA.
- ENS certificado – categoría ALTA.
- No lo sé / prefiero no contestar.

P1.5. Situación respecto a NIS2

- Claramente dentro del ámbito NIS2 como entidad esencial.
- Dentro del ámbito NIS2 como entidad importante.
- Afectación indirecta (por ser proveedor de organizaciones NIS2).
- No afectada (que sepamos, todavía).
- No lo sé / prefiero no contestar.

Bloque 2 – Gobernanza, riesgo y métricas (visión general)

P2.1. Existencia de un marco formal de gestión de riesgos de ciberseguridad

- Sí, contamos con un marco formal documentado y aprobado (por ejemplo, alineado con ISO 27005, NIST, ENS u otros).
- Existe un marco informal; se gestiona el riesgo, pero la documentación es... aspiracional.
- No hay marco formal; se gestionan riesgos de forma reactiva caso a caso.
- No lo sé / prefiero no contestar.

P2.2. ¿Con qué frecuencia se revisan de forma estructurada los riesgos de ciberseguridad?

- Al menos una vez al año, con participación de la alta dirección.
- Al menos una vez al año, pero restringido al ámbito técnico.
- Solo cuando hay un incidente serio o una auditoría externa.
- No existe proceso periódico de revisión de riesgos.

P2.3. Implicación de la alta dirección en decisiones de ciberseguridad

- La alta dirección participa regularmente en comités donde se revisan indicadores, riesgos y planes de ciberseguridad.
- La alta dirección se implica puntualmente (ante proyectos grandes, incidentes o auditorías).
- La alta dirección se informa mediante resúmenes esporádicos; la toma de decisiones se delega casi por completo.
- La alta dirección se entera por la prensa o cuando “algo se cae”.

P2.4. Disponibilidad de indicadores cuantitativos de ciberseguridad (KPIs/KRIs)

- Sí, mantenemos un cuadro de mando con indicadores definidos, revisados y con objetivos claros.
- Tenemos indicadores, pero sin objetivos formales ni revisión periódica.
- Hay algunos datos dispersos (logs, tickets), pero no un cuadro de mando como tal.
- No trabajamos con indicadores cuantitativos; preferimos el arte ancestral del “olfato”.

P2.5. Existencia de un índice global de madurez (IGM) de ciberseguridad

- Sí, calculamos un índice de madurez (propio o basado en modelos como SAMM, NIST CSF, etc.).
- Estamos en proceso de definirlo.
- No, pero usamos evaluaciones cualitativas sin índice numérico.
- No, y no está previsto por el momento.

Bloque 3 – OWASP Top 10:2025 (exposición y tratamiento)

P3.1. Conocimiento interno del OWASP Top 10:2025

- Es conocido y utilizado de forma habitual por equipos de desarrollo, seguridad y auditoría.
- Es conocido principalmente por el equipo de seguridad; en desarrollo suena “de oídas”.
- Solo se menciona en formaciones u ocasionalmente en auditorías.
- No tenemos conciencia práctica del Top 10:2025.

P3.2. Mapeo de vulnerabilidades internas a categorías OWASP Top 10:2025

- Siempre: todas las vulnerabilidades relevantes se mapean sistemáticamente a categorías del Top 10.
- Frecuentemente, para vulnerabilidades de criticidad media o alta.
- Ocasionalmente, cuando lo piden auditorías o informes específicos.
- Nunca o casi nunca; usamos otras taxonomías (o ninguna en particular).

P3.3. Identificación de la categoría OWASP más frecuente en sus sistemas en el último año

(Respuesta única basada en la mejor estimación disponible.)

- A01 – Broken Access Control.
- A02 – Security Misconfiguration.
- A03 – Software Supply Chain Failures.
- Otras categorías del Top 10 (especificar en comentarios).
- No disponemos de esa información aún.

P3.4. Cobertura de análisis frente al Top 10:2025

En las aplicaciones y APIs críticas:

- Contamos con pruebas (SAST/DAST/SCA/pentesting) mapeadas explícitamente a las diez categorías del Top 10:2025.
- Algunas pruebas se mapean al Top 10, pero no hay una cobertura sistemática.
- Se realizan pruebas de seguridad sin mapeo explícito al Top 10.
- No se realizan pruebas de seguridad específicas o son muy puntuales.

P3.5. Tiempo medio de remediación de vulnerabilidades asociadas al Top 10:2025 (MTTR)

(Para vulnerabilidades de criticidad alta o crítica.)

- Menos de 7 días.
- Entre 7 y 30 días.
- Entre 31 y 90 días.
- Más de 90 días.
- No se mide o no se dispone de ese dato.

P3.6. Prioridad relativa de A01–A03 en la gestión de vulnerabilidades

- Existe una prioridad explícita para vulnerabilidades asociadas a A01–A03 (política o procedimiento formal).
- Se priorizan de facto, aunque no exista una política formal.
- No se priorizan específicamente; se tratan igual que el resto según CVSS u otros criterios.
- No se diferencian en absoluto; “todas las vulnerabilidades son importantes”.

Bloque 4 – OWASP SAMM (madurez de programa)

P4.1. Uso de OWASP SAMM en la organización

- Sí, realizamos autoevaluaciones SAMM regulares (al menos cada 2 años).
- Lo hemos utilizado al menos una vez para una evaluación puntual.
- Conocemos SAMM pero aún no lo hemos utilizado.
- No conocíamos SAMM antes de esta encuesta.

P4.2. Cobertura organizativa de las autoevaluaciones SAMM

(Solo si ha respondido que sí en P4.1.)

- Las autoevaluaciones cubren a toda la organización relevante (TI, desarrollo, operaciones, negocio).
- Cubren principalmente áreas técnicas (desarrollo, operaciones); negocio participa marginalmente.
- Se limitan a proyectos o equipos específicos.
- No aplicable (no usamos SAMM).

P4.3. Nivel medio aproximado de madurez SAMM alcanzado

(Si se conoce el dato.)

- Entre 0 y 1.
- Entre 1 y 2.
- Entre 2 y 3.
- No se dispone de puntuación global, solo cualitativa.
- No aplicable / no usamos SAMM.

P4.4. Estado de la práctica SAMM “Strategy and Metrics”

- Nivel 0: no existen objetivos ni métricas claras de seguridad de software.
- Nivel 1: existen objetivos y algunas métricas definidas, pero no están alineadas con el negocio.
- Nivel 2: existe una estrategia unificada de seguridad de software con métricas asociadas.
- Nivel 3: la estrategia y las métricas están integradas y alineadas con indicadores de negocio y valor de activos.
- No se ha evaluado específicamente esta práctica.

P4.5. Uso de resultados SAMM para planificar inversiones

- Los resultados SAMM se utilizan explícitamente para priorizar inversiones y proyectos de seguridad.
- Se tienen en cuenta de forma orientativa, pero no determinan decisiones de inversión.
- Los resultados se elaboran “para la foto” y no se integran en la planificación real.
- No disponemos de resultados SAMM.

P4.6. Frecuencia de revisión de madurez SAMM

- Revisión anual o más frecuente.
- Revisión cada 2–3 años.
- Evaluación única sin seguimiento sistemático.
- No se revisa / no aplicable.

Bloque 5 – OWASP ASVS 5.0 (verificación técnica)

P5.1. Conocimiento y uso de OWASP ASVS

- ASVS está formalmente adoptado como estándar interno de requisitos de seguridad para aplicaciones.
- ASVS se utiliza como referencia en algunos proyectos o auditorías, pero no de forma sistemática.
- Se conocen sus principios, pero no se aplica formalmente.
- No se conoce ni se aplica ASVS.

P5.2. Clasificación de aplicaciones según niveles ASVS

- Todas las aplicaciones tienen asignado un nivel ASVS (1, 2 o 3) en función de su criticidad.
- Solo las aplicaciones críticas tienen un nivel ASVS documentado.
- No se utilizan niveles ASVS, pero se emplean categorías de criticidad propias.
- No existe clasificación formal en términos de ASVS ni equivalente.

P5.3. Porcentaje aproximado de aplicaciones críticas evaluadas al menos contra ASVS Nivel 2

- 0–25 %.
- 26–50 %.
- 51–75 %.
- 76–100 %.
- No se dispone de esta información.

P5.4. Uso de ASVS en el ciclo de vida de desarrollo (SDLC)

- Integrado en el “definition of done” y en criterios de aceptación de historias de usuario.
- Utilizado como checklist en revisiones de diseño y código.
- Empleado únicamente en auditorías externas o pentests puntuales.
- No se utiliza ASVS en el SDLC.

P5.5. Cobertura de pruebas automatizadas frente a requisitos ASVS

- Se mide de forma explícita el porcentaje de requisitos ASVS cubiertos por pruebas automatizadas.
- Existen pruebas automatizadas de seguridad, pero sin trazabilidad directa a requisitos ASVS.
- Solo se realizan pruebas manuales de seguridad.
- No se realizan pruebas de seguridad específicas.

P5.6. Densidad de requisitos ASVS no cumplidos detectados en producción

- Se dispone de indicadores que miden requisitos ASVS no cumplidos descubiertos a través de incidentes o auditorías en producción.
- Se registran hallazgos, pero no se miden explícitamente frente a ASVS.
- No se mide ni se relaciona con ASVS.

Bloque 6 – Metodología OWASP de Rating de Riesgo

P6.1. Uso de la Metodología de Rating de Riesgo de OWASP

- Se utiliza de forma sistemática para evaluar riesgos de aplicaciones.
- Se utiliza como referencia, combinada con otros marcos (CVSS, ISO 27005, etc.).
- No se utiliza, pero podría adoptarse en el futuro.
- No se conoce esta metodología.

P6.2. Factores considerados habitualmente en la evaluación de riesgos de aplicaciones (Marque todas las que apliquen.)

- Probabilidad de explotación basada en factores del agente de amenaza (capacidad, motivación, oportunidad).
- Facilidad de descubrimiento y explotación de las vulnerabilidades.
- Impacto técnico (confidencialidad, integridad, disponibilidad, trazabilidad).
- Impacto de negocio (financiero, reputacional, legal, sobre personas).
- Principalmente la puntuación CVSS de la vulnerabilidad, sin matices adicionales.

P6.3. Clasificación del riesgo resultante (salida)

- Score numérico normalizado (por ejemplo, 1–10) con umbrales definidos para bajo/medio/alto.
- Clasificación cualitativa (bajo/medio/alto) sin un score numérico explícito.
- Se decide caso a caso, sin criterios comunes bien definidos.
- No existe un proceso de clasificación explícito.

P6.4. Uso de los resultados de riesgo en la priorización de remediación

- Los valores de riesgo (score o nivel) determinan explícitamente los plazos máximos de remediación.
- El riesgo se tiene en cuenta, pero hay excepciones frecuentes que no siguen la prioridad teórica.
- El riesgo no se utiliza sistemáticamente para priorizar; manda la urgencia percibida o la presión externa.
- No se realiza priorización estructurada; se resuelve “lo que se puede cuando se puede”.

P6.5. Participación de la alta dirección en la aceptación de riesgos altos

- Toda aceptación de riesgos altos requiere decisión de la alta dirección documentada.
- En teoría, sí; en la práctica, las aceptaciones se resuelven a nivel técnico/intermedio.
- No existe un proceso formal de aceptación de riesgos.
- No se acepta riesgo; todo se “asume” por defecto sin análisis formal.

Bloque 7 – Cultura, formación y capacidades humanas

P7.1. Formación en OWASP (Top 10, SAMM, ASVS) para personal técnico

En el último año, el porcentaje aproximado de personal técnico (desarrollo, operaciones, arquitectura, seguridad) que ha recibido formación basada en OWASP es:

- 0–25 %.
- 26–50 %.
- 51–75 %.
- 76–100 %.
- No se dispone de esta información.

P7.2. Programas de concienciación para personal no técnico

- Existen programas periódicos de concienciación (al menos anuales) adaptados a perfiles no técnicos.
- Se realizan acciones puntuales (charlas, correos, cartelería) sin continuidad clara.
- Solo se forma al personal tras un incidente o cuando lo exige una auditoría.
- No hay un programa de concienciación estructurado.

P7.3. "Security champions" en equipos de desarrollo

- Todos o casi todos los equipos cuentan con al menos una persona identificada formalmente como "security champion".
- Algunos equipos cuentan con figuras informales que ejercen ese rol.
- No existe tal figura; la seguridad se centraliza en un equipo especializado.
- No aplica (no desarrollamos software propio).

P7.4. Cultura de reporte interno de vulnerabilidades

- Existe un canal claro y utilizado para reportar debilidades de seguridad (internas o de terceros), con reconocimiento al personal que las identifica.
- Existe un canal, pero su uso es limitado y no hay un reconocimiento explícito.
- El reporte de vulnerabilidades se percibe como algo potencialmente "problemático" para quien reporta.
- No existe un canal claro ni cultura de reporte interno.

P7.5. Tiempo desde el descubrimiento de una vulnerabilidad crítica hasta su inclusión en la agenda de la alta dirección

- Menos de 48 horas.
- Entre 2 y 7 días.
- Entre 8 y 30 días.
- Solo en casos excepcionales o mediáticos.
- No se eleva a la alta dirección de forma sistemática.

Bloque 8 – Cadena de suministro y terceros (A03 y NIS2)

P8.1. Inventario y clasificación de proveedores TIC críticos

- Existe un inventario actualizado con clasificación de criticidad (incluyendo proveedores cloud, de software, integradores y servicios gestionados).
- Existe un inventario parcial o desactualizado.
- El inventario se limita a contratos clave; no cubre toda la dependencia real.
- No hay un inventario sistemático; nos enteramos de quién es crítico cuando falla.

P8.2. Evaluación de seguridad de proveedores TIC

- Se realizan evaluaciones estructuradas (cuestionarios, auditorías, certificaciones) antes de la contratación y de forma periódica.
- Se piden evidencias básicas (ISO 27001, ENS, etc.) pero sin evaluación en profundidad.
- La evaluación de seguridad es más bien informal o basada en la reputación del proveedor.
- No se realiza evaluación significativa de seguridad de proveedores.

P8.3. Requisitos OWASP/ASVS en contratos con terceros

- Se incluyen requisitos explícitos basados en OWASP (Top 10, ASVS) en contratos y pliegos.
- Se incluyen requisitos genéricos de "seguridad de aplicaciones" sin referencia explícita a OWASP.
- No se incluyen requisitos específicos más allá de cláusulas legales genéricas.
- No aplica (no se externalizan desarrollos ni servicios TIC críticos).

P8.4. Gestión de vulnerabilidades en componentes de terceros (dependencias, librerías, imágenes)

- Existe un proceso formal de gestión de vulnerabilidades de componentes de terceros (SCA, SBOM, procedimientos de parcheo, etc.).
- Existen prácticas parciales, impulsadas principalmente por algunos equipos.
- La gestión de vulnerabilidades en componentes es reactiva, tras incidentes o avisos públicos.
- No existe un proceso específico para dependencias y componentes.

Bloque 9 – Operaciones, incidentes y continuidad

P9.1. Registro y gestión de incidentes de seguridad

- Existe un proceso formal con registro centralizado, clasificación, análisis de causa raíz y seguimiento.
- Se registran incidentes de cierta relevancia, pero sin un proceso formal completo.
- Solo se registran incidentes muy graves o aquellos que trascienden externamente.
- No existe un proceso claro de gestión de incidentes.

P9.2. Coordinación con CSIRTs nacionales (INCIBE-CERT, CCN-CERT)

- Mantenemos canales establecidos y utilizamos regularmente los servicios de estos CSIRTs.
- Se ha contactado en algunas ocasiones, pero no de forma sistemática.
- No se ha utilizado su apoyo, aunque se conoce su existencia.
- No se conocen ni se utilizan estos recursos.

P9.3. Planes de continuidad y recuperación ante desastres

- Existen, se prueban periódicamente y cubren escenarios de ciberincidentes maje